

ge-vernova-proficy brief

GE Vernova / Proficy Firmware Attack Surface & Detection Brief

Scope: 8 product lines (Proficy iFIX 2024 / 6.5+, Proficy CIMPLICITY 11.x / 12.x, Proficy Historian 2024, Proficy Operations Hub, Proficy Plant Applications, Proficy Workflow, Proficy CSense, Proficy Tracker) across 5 architecture classes — **research-only brief; firmware extraction is pending** (no on-host catalog yet; no `firmware-staging/GE-Vernova/` rootfs walk performed). Hash count: 0 (analyst queue priming only). Findings combine GE Vernova / GE Digital PSIRT bulletins, CISA ICS advisories (notably ICSA-24-051-02 iFIX, ICSA-22-326-04 CIMPLICITY, ICSA-23-269-01 Historian), NVD CVE records, and named research from Claroty Team82 and Forescout Vedere Labs. Water-utility relevance is the primary lens: Proficy iFIX is the legacy incumbent HMI/SCADA in pre-2018 municipal water/wastewater control centers (FDA 21 CFR Part 11 audit-trail capability is re-used for SDWA compliance reporting), and is the dominant displacement target of modern Linux Ignition deployments.

Purdue layer mapping: Group A (Proficy iFIX + CIMPLICITY SCADA servers) and Group B (Proficy Historian + Operations Hub data tier) sit at **Purdue L3 (Site Operations)** — see [purdue-l3-site-operations-brief.md](#). Group C (iWorkstation, CimEdit/CimView engineering tooling) sits at **Purdue L3 EWS** — same brief. Group D (Proficy iFIX runtime / WorkSpace view-only stations on operator panel PCs) lives at **Purdue L2 (Area Supervisory)** — see [purdue-l2-area-supervisory-brief.md](#). Group E (Proficy Plant Applications, Workflow, CSense, Tracker MES suite) cross-cuts **Purdue L3 and L4**, with the cloud/historian-roll-up flows touching **L3.5 IT/OT Boundary** — see [purdue-l35-it-ot-boundary-brief.md](#). Downstream Series 90 / RX3i / VersaMax / Mark VIe controllers SRTP-fed by the SCADA layer live at **L1** — see [purdue-l1-basic-controllers-brief.md](#). Safety interlocks the operator view can mask (Mark VIeS, third-party SIS) — see [purdue-safety-systems-brief.md](#).

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. SCADA / HMI Server	L3 Site Operations	Proficy iFIX 2024 / 6.5+ server, Proficy CIMPLICITY 11.x / 12.x server	Windows Server + .NET + iFIX SCU/WorkSpace services, CIMPLICITY Project Runtime + CimView; SRTP TCP/18245 + OPC UA + OPC DA + Modbus TCP	research-only (pending)
B. Historian + Operations Hub	L3 Site Operations	Proficy Historian 2024, Proficy Operations Hub	Windows Server + SQL Server backend + IIS-hosted Operations Hub web + Historian data collectors (TCP/14000 default)	research-only (pending)
C. Engineering workstations	L3 EWS	Proficy iFIX iWorkstation / iClient, CIMPLICITY CimEdit / CimView project editor	Windows admin host + project files (.cim , .cig , .grf , .fxg) + database manager	research-only (pending)
D. HMI runtime / panel PCs	L2 Area Supervisory	Proficy iFIX WorkSpace runtime view-only, CIMPLICITY CimView runtime panel	Windows / Windows Embedded panel PC + view-only runtime + alarm summary	research-only (pending)
E. MES suite	L3 / L4 cross-cut (L3.5 for cloud)	Proficy Plant Applications, Proficy Workflow, Proficy CSense, Proficy Tracker	Windows Server + SQL Server + IIS web tier + .NET services; talks north to ERP, south to Historian + SCADA	research-only (pending)

Group A — SCADA / HMI Server (Proficy iFIX + CIMPLICITY) — Purdue L3 (Site Operations)

Direct attack surface (per GE Vernova install / hardening docs):

SRTP TCP/18245 (Series 90 / RX3i legacy comms, historically unauthenticated) •
 iFIX NetworkSession services (RPC + dynamic ports) • iFIX SCU configuration shares •
 CIMPLICITY Project Runtime IPC + Router (TCP/32000-32256 range) •
 OPC DA / OPC UA • Modbus TCP 502 • MS SQL Server (Historian + Plant Apps, 1433) •
 SMB / NetBIOS for project-file shares and integrator-laptop sync

Proficy iFIX and CIMPLICITY both run as **SYSTEM-privileged Windows services** with the project / SCU database on a writable share. Every Group A vulnerability is fundamentally a Windows server compromise that hands the attacker the SCADA runtime.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
Proficy iFIX 2024 advisory family	High	Proficy iFIX (Workstation + Network install paths)	Local privilege escalation via insecure default permissions	ICSA-24-051-02
CVE-2022-2792	7.8	Proficy CIMPLICITY	Uncontrolled search path → DLL hijack / RCE	ICSA-22-326-04
Proficy iFIX historical default <code>ADMIN/ADMIN</code> baseline	—	Proficy iFIX pre-2014 cleanup	Default-credential class in legacy deployments	GE Vernova / GE Digital PSIRT portal
Claroty Team82 — Proficy iFIX / CIMPLICITY research	—	Proficy iFIX + CIMPLICITY	Project-file parser + IPC bug family	Claroty Team82 research

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) into the CIMPLICITY Router / iFIX NetworkSession service, chained to [T0836 Modify Parameter](#) via SRTP writes to Series 90 / RX3i — the legacy unauth SRTP pattern is unchanged from the Series 90 era.

Group B — Historian + Operations Hub — Purdue L3 (Site Operations)

Direct attack surface (per Proficy Historian + Operations Hub docs):

Historian data collector TCP/14000 (legacy collector port) ·
Historian Web Admin HTTPS/8443 · Operations Hub HTTPS/443 (IIS) ·
REST API on the OH web tier · SQL Server backend 1433 ·
OPC HDA / OPC UA collectors · Excel add-in client RPC

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
Proficy Historian 2023 advisory family	High	Proficy Historian	Unauthenticated file overwrite class	ICSA-23-269-01
Operations Hub web auth-handling family	—	Proficy Operations Hub	Web tier auth / session handling	GE Vernova PSIRT advisories

CVE	CVSS	Product	Vector	Status
Historian collector trust class	—	Proficy Historian collectors	Implicit trust between collector + archiver	Forescout Vedere Labs

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) against the Historian collector / OH REST API, chained to [T0832 Manipulation of View](#) via fabricated tag values rendered in Operations Hub dashboards — the historian is the compliance-reporting truth source for SDWA in water utilities, so fabricated history is fabricated regulatory evidence.

Group C — Engineering workstations (iWorkstation + CimEdit) — Purdue L3 EWS

iWorkstation and CimEdit hold credentials and project trust to every Proficy iFIX and CIMPLICITY runtime at the site. CIMPLICITY screen files (`.cim` , `.cig`) and Proficy iFIX picture files (`.grf` , `.fxg`) are parsed by the runtime — **the screen-file parser is a recurring attack surface and the integrator-laptop pivot is a supply-chain route to every site the integrator services**. CVE-2022-2792 (CIMPLICITY uncontrolled search path) is the Group C foothold pattern. Claroty Team82 has consistently published Proficy iFIX/CIMPLICITY project-file parser findings — track [Claroty Team82 research](#) and [CISA ICS advisories index](#) for the `CIMPLICITY` / `iFIX` keyword.

Top attack vector (MITRE ATT&CK ICS): [T0862 Supply Chain Compromise](#) of an integrator's laptop, followed by [T0889 Modify Program](#) when the integrator next deploys to a site.

Group D — HMI runtime / panel PCs — Purdue L2 (Area Supervisory)

Proficy iFIX WorkSpace runtime and CIMPLICITY CimView execute on hardened Windows / Windows Embedded panel PCs in front of operators. These are rarely patched (every patch is an operator-disrupting reboot), so the CIMPLICITY screen-file parser class (CVE-2022-2792 family) and any Proficy iFIX picture-parser bugs persist for years.

Top attack vector (MITRE ATT&CK ICS): [T0832 Manipulation of View](#) by delivering a tampered `.cim` / `.grf` to the panel via the project-file deploy path, then [T0833 Modify Control Logic](#) once the runtime executes the panel-side script.

Group E — MES suite (Plant Applications, Workflow, CSense, Tracker) — Purdue L3 / L4 cross-cut

Proficy Plant Applications, Workflow, CSense, and Tracker run as Windows Server / IIS / SQL stacks straddling the L3 SCADA edge and L4 ERP. They consume Historian data and OPC tags and can write back to SCADA via the Plant Apps event server. Track [GE Vernova PSIRT advisories](#) for the Plant Applications keyword; the IIS web tier is the canonical external entry. Forescout's L3.5 IDMZ research applies — see [Forescout Vedere Labs](#).

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) against the Plant Apps web tier → SQL backend → tag write to SCADA via the event server.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Windows Security (iFIX / CIMPLICITY server)	EventID 4624 Type 3 to SCADA server outside engineering hours from non-EWS source	Lateral move onto iFIX SCU / CIMPLICITY project	T0866
2	Proficy iFIX audit trail (21 CFR Part 11)	<code>Security.SignOn</code> failure burst + success, or new <code>User.Add</code> outside change window	Brute force / persistence on the audit-trail user store	T0812 Default Credentials
3	CIMPLICITY event log	Project <code>Configuration.Update</code> or <code>Screen.Deploy</code> outside change window	Tampered <code>.cim/ .cig</code> deploy	T0836
4	Historian message log	Unauthenticated file overwrite signature (ICSA-23-269-01 class) or anomalous collector add	Direct CVE exploit + persistence	T0866
5	Network IDS (Suricata/Zeek)	SRTP TCP/18245 from outside L3 SCADA VLAN to RX3i / Series 90	Direct unauth PLC write	T0855 Unauthorized Command Message
6	Network IDS	Modbus function codes 5/6/15/16 crossing L3 → L1 from SCADA server with no scheduled change	Lift/pump station control-logic tamper	T0833

#	Source	Event	What it catches	MITRE ATT&CK ICS
7	Sysmon on EWS	EventID 7 ImageLoad on CimEdit.exe / iFIX*.exe / Workspace.exe loading DLL from user-writable path	CVE-2022-2792 / ICSA-24-051-02 class	T0866
8	IIS log (Operations Hub)	Anomalous POST /OperationsHub/api/ burst from non-engineer source	Web tier exploit attempts	T0866

Secondary: Proficy iFIX 21 CFR Part 11 audit trail (re-used for SDWA compliance) — forward via Windows Event Forwarding to SIEM; CIMPLICITY event log + Project Runtime trace; Historian message log + Excel add-in client connect log; Operations Hub web request log; OPC UA server session log on the iFIX OPC server; SQL Server audit on Historian + Plant Apps DB (`sp_addlogin` / `sp_addrolemember` outside maintenance); OT-native anomaly — tag-write rate spike from iFIX runtime to a Modbus / SRTMP RTU with no operator interaction; sudden disable of an iFIX alarm group (alarm-suppression class — see MITRE ATT&CK ICS T0878 referenced in [CISA ICS guidance](#)); Historian tag step-change that does not match the process model (fabricated SDWA-reporting data); firewall egress from SCADA VLAN — iFIX / CIMPLICITY servers should never originate outbound to internet.

Specific zero-day-ish concerns for your dataset

1. **ICSA-24-051-02 Proficy iFIX local privilege escalation (Workstation + Network install paths) is the single highest-priority untriaged surface in the long-tail iFIX installed base.** Many municipal water iFIX hosts have not patched [ICSA-24-051-02](#) because the patch is operator-disrupting. First check on any iFIX site: confirm the installed iFIX build is post-fix and that the Workstation/Network install path ACLs were re-tightened.
2. **CIMPLICITY screen-file (`.cim` / `.cig`) parser is a recurring attack surface and the integrator-laptop pivot is supply-chain to every site the integrator services.** A single compromised integrator laptop (Group C) gets every CIMPLICITY site they touch on their next deploy. Detection only via project-file hashing baseline + CimEdit Sysmon. Track CVE-2022-2792 family advisories at [ICSA-22-326-04](#).
3. **ICSA-23-269-01 Proficy Historian unauthenticated file overwrite class is a direct path to fabricated SDWA compliance evidence.** [ICSA-23-269-01](#). The Historian is the audit-trail truth source water utilities show regulators; an attacker who can overwrite arc files can rewrite the regulatory record after the fact.

4. **SRTP TCP/18245 is historically unauthenticated** and still in widespread use to legacy Series 90 / RX3i / VersaMax controllers in municipal water plants. There is no in-protocol authentication retrofit — only network segmentation + IDS. Any SRTP from outside the SCADA VLAN is by definition unauthorized.
 5. **Proficy iFIX historical default `ADMIN/ADMIN` baseline pre-2014 cleanup persists in long-tail municipal installs.** First field check: try `ADMIN/ADMIN` on the iFIX security path. Inventory iFIX security groups and confirm the audit-trail user store does not still carry the legacy default ([T0812 Default Credentials](#)).
-

Water-utility deployment pattern (the primary use case)

Proficy iFIX is THE legacy incumbent HMI/SCADA in pre-2018 municipal water and wastewater control centers — the platform that modern Linux Ignition builds are explicitly displacing. The common stack: a **Proficy iFIX SCADA server pair on Windows Server in the control center**, talking SRTP TCP/18245 (legacy GE Series 90 / RX3i), OPC UA, and Modbus TCP **south to lift-station and pump-station PLCs** — most often Allen-Bradley CompactLogix or Schneider Modicon M340 in the brownfield, with GE RX3i where the utility stayed on-vendor. Proficy Historian aggregates tag history for SDWA compliance reporting; the Proficy iFIX 21 CFR Part 11 audit-trail feature (built for pharma) is the same channel water utilities lean on for SDWA.

Aliquippa / Volt Typhoon threat context: The November 2023 Municipal Water Authority of Aliquippa (PA) intrusion — Iranian-affiliated CyberAv3ngers defacing a Unitronics Vision-series HMI at a booster station — and the parallel CISA / NSA / FBI / EPA advisories on **Volt Typhoon prepositioning in U.S. water and wastewater OT networks** elevated municipal water from theoretical to active-target status. Proficy iFIX control centers are the exact Purdue L3 layer Volt Typhoon TTPs target for living-off-the-land persistence: Windows Server hosts running unmanaged SYSTEM services (iFIX NetworkSession, CIMPLICITY Router), seldom-patched because every patch is an operator-disrupting reboot, with SRTP / Modbus / OPC trust paths south to the lift-station PLCs that actually run the chemical-dosing and pump logic. The Aliquippa incident demonstrated that small-utility OT is reachable from the internet with default credentials; the same hygiene gap (default `ADMIN/ADMIN`, unsegmented SRTP, integrator laptops with project trust) is what makes the long-tail Proficy iFIX installed base a Volt Typhoon-prepositioning target. See [CISA Water and Wastewater sector resources](#) and the joint [CISA Volt Typhoon advisory](#).

Water-utility threat-modeling priority: **Group A Proficy iFIX server > Group C integrator laptop (the contractor-network pivot the TTX scenario centers on) > Group D panel PCs at the plant > Group B Historian (compliance-record integrity) > Group E MES (rare in pure water; present in combined water-and-power utilities).** The contractor / integrator path is the canonical compromise route: a contractor laptop with CimEdit and a Proficy iFIX iWorkstation client carries deployable project trust to every utility they service — see [purdue-l1-basic-controllers-brief.md](#) for

the downstream lift-station RTU layer where [T0836 Modify Parameter](#) on chemical-dosing setpoints, [T0855 Unauthorized Command Message](#) on pump start/stop, and worst-case [T0879 Damage to Property](#) on clearwell or chlorine systems play out.

Sources

- [GE Vernova Cyber Security advisories portal](#)
- [CISA ICS Advisory ICSA-24-051-02 — Proficy iFIX](#)
- [CISA ICS Advisory ICSA-22-326-04 — Proficy CIMPLICITY \(CVE-2022-2792\)](#)
- [CISA ICS Advisory ICSA-23-269-01 — Proficy Historian](#)
- [NVD — CVE-2022-2792](#)
- [CISA ICS Advisories index](#)
- [Claroty Team82 — ICS/OT research](#)
- [Forescout Vedere Labs — Research Labs](#)
- [Dragos — ICS threat intelligence blog](#)
- [CISA Volt Typhoon joint advisory \(AA24-038A\)](#)
- [CISA Water and Wastewater sector resources](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [MITRE ATT&CK for ICS — T0832 Manipulation of View](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0855 Unauthorized Command Message](#)
- [MITRE ATT&CK for ICS — T0862 Supply Chain Compromise](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [MITRE ATT&CK for ICS — T0879 Damage to Property](#)
- [MITRE ATT&CK for ICS — T0889 Modify Program](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)